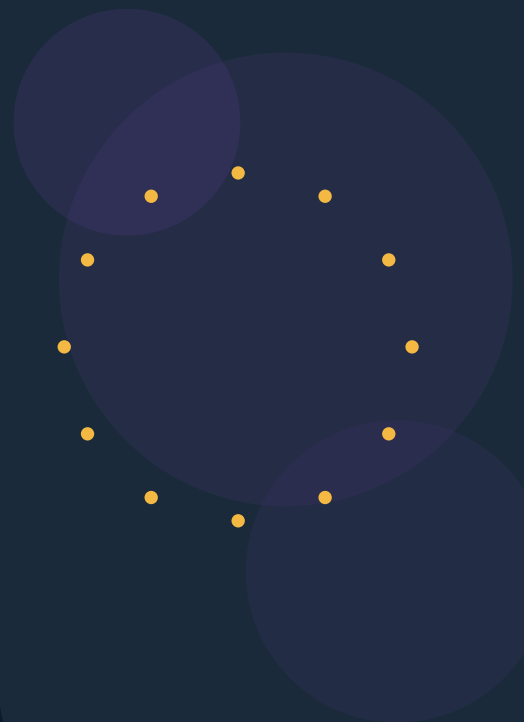


GUIDA OPERATIVA

CRA — Guida Operativa

Protocollo completo per consulenti e team di conformità
Dal primo audit al marchio CE: ogni passo spiegato



TIPO DOCUMENTO:

Manuale Operativo — Protocollo di Audit CRA

Regolamento (UE) 2024/2847 · Cyber Resilience Act

Conformità obbligatoria: 11 dicembre 2027 · Edizione 2025

Come usare questa guida operativa

Questa guida è un **protocollo operativo sequenziale** per valutare la conformità al Cyber Resilience Act (CRA) di un'azienda e portarla all'apposizione del marchio CE*. È strutturata in 6 fasi che coprono l'intero processo: dal primo incontro con il cliente alla firma della Dichiarazione di Conformità UE.

Ogni fase include: **obiettivo** preciso, **domande da porre** al cliente, **documenti da raccogliere**, **strumenti tecnici** consigliati, **checklist** di verifica con item spuntabili (■), e **output atteso** per passare alla fase successiva. Le checklist usano ■ per gli item da completare.

6	47+	3 anni	€ 15M
Fasi del processo	Checklist item totali	Tempo disponibile per conformarsi	Sanzione max per violazione

■ **Tempistiche tipiche di un progetto CRA:**

Azienda con 1-3 prodotti non critici: 3-6 mesi, costo indicativo € 15.000-40.000. Azienda con prodotti Classe I: 6-12 mesi, costo indicativo € 40.000-100.000. Azienda con prodotti Classe II: 12-24 mesi, costo indicativo € 100.000-300.000+. I costi variano in base a: complessità tecnica del prodotto, numero di prodotti nel perimetro, maturità iniziale dei processi di sicurezza, se è necessario un CAB* esterno.

1

FASE 1 — KICK-OFF E RACCOLTA INFORMAZIONI

Obiettivo

1.1 — Riunione di kick-off

Organizza una riunione con: CEO o General Manager (per il contesto business), CTO o Responsabile Tecnico (per i dettagli di prodotto), Legal Counsel o Responsabile Compliance (per aspetti normativi), CISO* o Responsabile IT (per sicurezza). Durata consigliata: 2-3 ore.

Domande obbligatorie da porre durante il kick-off:

- Quali prodotti (hardware e/o software) vende l'azienda nell'Unione Europea? Elencali tutti, incluse le versioni.
- Questi prodotti contengono componenti software? Si connettono a reti (Wi-Fi, Internet, Bluetooth, Ethernet, 4G/5G)?
- L'azienda sviluppa internamente il software (in-house development) o usa principalmente componenti di terze parti e codice open source?
- Esistono già processi formali di gestione delle vulnerabilità (vulnerability management)? Come vengono gestiti gli aggiornamenti di sicurezza?
- Sono stati effettuati in passato test di sicurezza (penetration test, vulnerability assessment)? Esistono i report?
- L'azienda ha già certificazioni di sicurezza (ISO 27001, SOC 2, ISO 27034, IEC 62443)?
- Ha già esperienza con la marcatura CE per altri regolamenti (sicurezza elettrica, EMC, RED)?
- Qual è la dimensione dell'azienda: numero di dipendenti, fatturato annuo? È PMI* o microimpresa?
- Quali sono i mercati di vendita (solo Italia, tutta Europa, extra-UE)?
- Quali risorse (budget, persone dedicate, tempo) sono disponibili per il progetto CRA?
- Esiste un responsabile interno che coordinerà il progetto CRA dal lato cliente?
- Esistono scadenze commerciali (lancio di nuovi prodotti, rinnovo contratti) che influenzano il timing del progetto?

1.2 — Documenti da richiedere prima della prossima riunione

- Listino prodotti completo con: nome, versione corrente, descrizione funzionale di ciascuno
- Architettura di sistema di ogni prodotto (diagrammi di rete, architettura software/hardware)
- Stack tecnologico: linguaggi di programmazione, framework, principali librerie di terze parti
- Risultati di eventuali audit di sicurezza precedenti o report di vulnerability assessment
- Contratti con fornitori di componenti software critici (SLA, responsabilità di sicurezza)
- Politiche di sicurezza esistenti (password policy, patch management policy, incident response plan)
- Organigramma del team tecnico (sviluppatori, DevOps, QA, chi si occupa di sicurezza?)
- Esempi di documentazione tecnica esistente (anche parziale) per ogni prodotto
- Codice di condotta o policy esistenti sulla gestione delle vulnerabilità segnalate esternamente
- Registro degli incidenti di sicurezza degli ultimi 2 anni (se disponibile)

1.3 — Output di fine Fase 1

- Report preliminare con lista dei prodotti potenzialmente nel perimetro CRA
- Prima valutazione della complessità del progetto (semplice/medio/complesso)
- Piano di progetto dettagliato con milestone, responsabilità e date
- Contratto/lettera di incarico firmato con scope, deliverable e compenso
- Matrice degli stakeholder (chi decide cosa nel progetto)

2 FASE 2 — ANALISI DEL PERIMETRO E CLASSIFICAZIONE

Obiettivo

2.1 — Albero decisionale per ogni prodotto

Per ogni prodotto identificato nella Fase 1, segui questa sequenza di domande. Documenta la risposta e la motivazione per ogni domanda — questa documentazione fa parte del fascicolo tecnico.

D1	Domanda: Il prodotto è esclusivamente per usi militari o sicurezza nazionale? ■ Se SÌ: SÌ → Escluso dal CRA. Documenta l'esclusione per iscritto con riferimento all'Art. 2, par. 6. ➡ ■ Se NO: NO → Continua alla domanda D2
D2	Domanda: Il prodotto è un dispositivo medico soggetto a MDR* (UE) 2017/745 o IVDR (UE) 2017/746? ■ Se SÌ: SÌ → Escluso dal CRA. Nota: MDR e IVDR includono già requisiti di cybersicurezza che devono essere rispettati. ➡ ■ Se NO: NO → Continua alla domanda D3
D3	Domanda: Il prodotto è soggetto al Regolamento veicoli (UE) 2019/2144 o al Regolamento aviazione (UE) 2018/1139? ■ Se SÌ: SÌ → Escluso dal CRA per i requisiti già coperti da tali regolamenti specifici. ➡ ■ Se NO: NO → Continua alla domanda D4
D4	Domanda: È software open source distribuito GRATUITAMENTE al di fuori di attività commerciali? ■ Se SÌ: SÌ → Probabilmente escluso. Verifica attentamente con l'Art. 2, par. 1: se integrato in un prodotto commerciale, potrebbe comunque essere nel perimetro. ➡ ■ Se NO: NO → Continua alla domanda D5
D5	Domanda: Il prodotto contiene elementi digitali (software, firmware, hardware con microcontrollore, connessione di rete) ED è immesso sul mercato UE? ■ Se SÌ: SÌ → Il prodotto È nel perimetro CRA → Procedi con la classificazione (sezione 2.2) ➡ ■ Se NO: NO → Il prodotto è probabilmente escluso. Documenta la motivazione.

2.2 — Classificazione per categoria di rischio

Per i prodotti nel perimetro CRA, consulta gli Allegati III e IV del Regolamento (disponibili su eur-lex.europa.eu cercando 'Regolamento UE 2024/2847'). Applica questa logica di classificazione:

DOMANDA	SE SÌ → CATEGORIA	PROCEDURA DI CONFORMITÀ
Il prodotto è nell'Allegato IV?	■ ALTAMENTE CRITICO	Schema EUCS* (EU Cybersecurity Certification Scheme) obbligatorio.
Il prodotto è nell'Allegato III, Parte 2?	■ CRITICO CLASSE II	Valutazione obbligatoria da CAB* accreditato (nessuna autovalutazione).

Il prodotto è nell'Allegato III, Parte 1?	■ CRITICO CLASSE I	Standard armonizzati UE oppure valutazione CAB* (a scelta del produttore).
Il prodotto non è in nessuna lista degli allegati?	■ NON CRITICO	Autovalutazione interna sufficiente. Nessun ente esterno necessario.

■ Cosa trovare nell'Allegato III — Classe I (esempi principali):

Browser Internet, gestori di password (password manager), software antivirus e anti-malware, reti private virtuali per uso consumer e PMI (VPN*), sistemi operativi per uso generale (desktop e server), router e switch di rete domestici e per PMI, microcontrollori con funzioni di sicurezza, smart meter (contatori intelligenti dell'energia), baby monitor connessi, giocattoli connessi. Allegato III — Classe II (esempi principali): sistemi operativi per infrastrutture critiche e sistemi industriali, firewall per ambienti industriali ICS*/SCADA*, sistemi di rilevamento delle intrusioni (IDS/IPS), sistemi PKI (Public Key Infrastructure), soluzioni di gestione delle identità e degli accessi privilegiati (PAM — Privileged Access Management), sistemi di lettura biometrica, industrial automation controllers.

3

FASE 3 — GAP ANALYSIS TECNICA APPROFONDATA

Obiettivo

3.1 — Metodologia dell'assessment tecnico

Organizza sessioni di assessment con il team tecnico dell'azienda (sviluppatori, architetti software, DevOps/DevSecOps*). Ogni sessione ha uno scopo definito. Per ogni requisito CRA, applica tre livelli di verifica:

L1 — Revisione documentale: Verifica l'esistenza di documentazione del requisito (policy, procedure, architetture).

Chiedi i documenti e verificane completezza, coerenza e aggiornamento. Domanda chiave: 'Esiste un documento che descriva come questo requisito è implementato?'

L2 — Verifica tecnica diretta: Analisi tecnica: revisione del codice sorgente per aspetti di sicurezza, verifica delle configurazioni di sistema e di rete, analisi dell'architettura con focus sulla sicurezza. Usa gli strumenti indicati nella sezione 3.2. Domanda chiave: 'Il requisito è effettivamente implementato nel codice/sistema?'

L3 — Test funzionale di verifica: Test pratici: vulnerability scan, test di configurazione, verifica del comportamento del sistema in condizioni avverse. Questo livello produce evidenze concrete per il fascicolo tecnico. Domanda chiave: 'Il requisito funziona correttamente anche sotto stress?'

3.2 — Strumenti tecnici per il gap analysis

Strumento	Tipo / Acronimo	Uso specifico nel CRA	Costo / Licenza
Syft (Anchore)	SBOM Generator (generatore di Distinta Base del Software)	Genera SBOM* (Software Bill of Materials) da container Docker, filesystem, artefatti binari. Supporta i formati CycloneDX* e SPDX*. Requisito V1.	Gratuito Open Source
Grype (Anchore)	CVE Scanner (scanner di vulnerabilità note)	Scansiona l'SBOM generato da Syft per identificare CVE* nelle dipendenze. Output: lista CVE con punteggio CVSS*, versione affected e versione fixed. Requisito 2a, V2.	Gratuito Open Source
Trivy (Aqua Security)	All-in-one Scanner (scanner completo)	Scanner completo per container Docker, filesystem, repository Git, Kubernetes. Identifica CVE*, segreti (password hardcoded), IaC* (Infrastructure as Code) misconfig, SBOM generation. Req. 2a, 2b, 2j, V1.	Gratuito Open Source
OWASP Dependency-Check	Dependency Vulnerability Scanner	Analisi vulnerabilità nelle dipendenze per Java (Maven, Gradle), .NET, Python (pip), Node.js (npm), Ruby (gems). Integrazione CI/CD*. Req. 2a.	Gratuito Open Source
Semgrep	SAST — Static Application Security Testing (analisi statica del codice)	Analisi del codice sorgente per vulnerabilità di programmazione: SQL injection, command injection, XSS, buffer overflow, uso di funzioni insicure. Req. 1, 2d-2k.	Community: gratuito Enterprise: a pagamento
SonarQube	SAST + Code Quality	Analisi statica codice sorgente con dashboard di sicurezza, quality gates (barriere di qualità), integrazione CI/CD*. Supporta 30+ linguaggi. Req. 1, 2a, 2j.	Community: gratuito Enterprise: a pagamento
OWASP ZAP (Zaproxy)	DAST — Dynamic Application Security Testing (test dinamico applicazione)	Test di penetrazione automatizzato per applicazioni web, API REST/SOAP. Scanner attivo e passivo. Req. 2a, 2d, 2j, 2k.	Gratuito Open Source

Burp Suite Community	DAST + Proxy (proxy di intercettazione web)	Proxy di intercettazione per analisi manuale del traffico web/API, fuzzing delle richieste. Community edition per test manuali. Req. 2a, 2d, 2j.	Community: gratuito Pro: ~€ 450/anno
CycloneDX CLI SPDX Tools	SBOM Validator (validatore di Distinta Base)	Validazione della correttezza formale e completezza degli SBOM* generati. Verifica la conformità agli standard CycloneDX* e SPDX*. Req. V1.	Gratuito Open Source
Shodan Censys	Attack Surface Discovery (scoperta della superficie di attacco)	Ricerca dispositivi e porte esposte su Internet. Utile per verificare cosa è visibile dall'esterno e identificare interfacce non necessariamente aperte. Req. 2j.	Shodan: freemium Censys: freemium
OpenVAS / Greenbone	VA Scanner (vulnerability assessment scanner)	Scanner di vulnerabilità di rete per infrastrutture. Identifica CVE* su servizi di rete esposti, misconfigurazioni di sistema. Req. 2a, 2b, 2j.	Gratuito Open Source
testssl.sh / SSL Labs	TLS/SSL Tester (tester della cifratura delle comunicazioni)	Verifica la configurazione TLS* (Transport Layer Security — protocollo di cifratura delle comunicazioni): versioni supportate, cipher suite, certificati. Req. 2e.	Gratuito Open Source

3.3 — Checklist completa del gap analysis

Usa questa checklist durante le sessioni di assessment. Per ogni item, assegna lo stato: ■ Conforme / ■■ Parzialmente conforme (documenta le lacune) / ■ Non conforme (gap da correggere) / N/A Non applicabile. Documenta le evidenze raccolte per ogni item: documento visionato, test eseguito, screenshot, ecc.

SICUREZZA DEL PRODOTTO — Allegato I, Parte 1	
Req. 1	■ Il prodotto è stato sottoposto a threat modeling formale e documentato (es. con metodologia STRIDE* o PASTA)? Il documento è aggiornato alla versione corrente del prodotto?
Req. 1	■ Il processo di sviluppo prevede code review con attenzione agli aspetti di sicurezza prima di ogni release? Esistono linee guida interne di secure coding?
Req. 2a	■ Il prodotto è stato scansionato con uno scanner di vulnerabilità (Trivy, Gype, OWASP DC)? Esistono CVE* con exploit pubblici noti (CISA KEV*) nelle dipendenze?
Req. 2a	■ Tutte le librerie di terze parti sono aggiornate alle ultime versioni stabili e sicure? Esiste un processo per mantenerle aggiornate?
Req. 2b	■ La configurazione di default del prodotto è sicura (no credenziali universali condivise tra tutti i dispositivi)?
Req. 2b	■ Ogni dispositivo o istanza ha credenziali di accesso uniche (generate in produzione, non fisse in firmware)?
Req. 2b	■ Solo le porte di rete strettamente necessarie sono aperte nella configurazione di default?
Req. 2b	■ Il prodotto permette il ripristino dello stato originale (factory reset) in modo semplice per l'utente?
Req. 2c	■ Il prodotto ha un meccanismo funzionante per ricevere e installare aggiornamenti di sicurezza?
Req. 2c	■ Gli aggiornamenti di sicurezza sono firmati digitalmente per garantirne autenticità e integrità?
Req. 2c	■ Gli aggiornamenti automatici di sicurezza sono abilitati di default (con opt-out per l'utente)?
Req. 2d	■ Sono implementati meccanismi di autenticazione forte (password complesse minimo 12 caratteri + complessità, o 2FA*/MFA* disponibile)?
Req. 2d	■ Esiste un meccanismo di account logout dopo un numero definito di tentativi di login falliti (es. blocco dopo 5-10 tentativi)?
Req. 2e	■ Le comunicazioni di rete usano TLS* 1.2 o superiore (TLS 1.3 consigliato)? TLS 1.0/1.1 e SSL sono disabilitati?
Req. 2e	■ I dati sensibili archiviati sono cifrati con AES-128 minimo (AES-256 raccomandato)?
Req. 2e	■ Le chiavi crittografiche non sono hardcoded nel codice sorgente? Sono gestite in modo sicuro (vault, HSM*)?
Req. 2f	■ Il firmware e il software sono firmati digitalmente? Il sistema verifica l'integrità prima dell'installazione?
Req. 2g	■ Il prodotto raccoglie solo i dati strettamente necessari al suo funzionamento (data minimization)? È documentato quali dati vengono raccolti e perché?
Req. 2h	■ Il prodotto implementa meccanismi di rate limiting per resistere ad attacchi DDoS* e di tipo brute force?
Req. 2j	■ Tutte le porte di rete e i servizi non necessari sono disabilitati nelle build di produzione?
Req. 2j	■ Le interfacce di debug, account di test e backdoor di sviluppo sono state rimosse dalle build di produzione?
Req. 2k	■ Sono implementate protezioni della memoria: ASLR*, DEP/NX*, PIE*, stack canaries?
Req. 2l	■ Il prodotto registra log degli eventi di sicurezza (accessi, modifiche configurazione, anomalie)?
Req. 2l	■ I log sono protetti da modifiche non autorizzate (append-only)? Conservati per periodo adeguato (>= 3 mesi)?
Req. 2m	■ Esiste una funzione di reset sicuro che sovrascrive realmente i dati dell'utente (non solo li marca come cancellati)?

GESTIONE VULNERABILITÀ — Allegato I, Parte 2

- Req. V1** ■ È stato generato un SBOM* in formato CycloneDX* o SPDX* per ogni prodotto nel perimetro CRA?
- Req. V1** ■ L'SBOM include almeno tutte le dipendenze di primo livello con versioni precise, identificatori PURL* e licenze?
- Req. V1** ■ L'SBOM viene aggiornato automaticamente ad ogni nuova build/versione del prodotto (integrato nel CI/CD*)?
- Req. V2** ■ Esiste un processo documentato per il monitoraggio continuo delle CVE* nelle dipendenze (es. abbonamento a feed NVD, GitHub Advisories)?
- Req. V2** ■ Sono definiti SLA* formali per la risoluzione delle vulnerabilità per ogni livello di gravità CVSS* (es. critiche in 14 gg, alte in 30 gg)?
- Req. V3** ■ È integrato un vulnerability scan automatico nel processo CI/CD* (a ogni build o almeno giornaliero)?
- Req. V3** ■ Viene eseguito un penetration test periodico (almeno annuale per prodotti Classe I/II)?
- Req. V4** ■ Vengono pubblicati security advisory dopo ogni patch di sicurezza rilasciata (su sito, mailing list, forum)?
- Req. V5** ■ È stata pubblicata una CVD* policy (Coordinated Vulnerability Disclosure) accessibile pubblicamente?
- Req. V5** ■ Esiste un indirizzo email dedicato (es. security@azienda.it) per ricevere segnalazioni di vulnerabilità?
- Req. V6** ■ Le vulnerabilità nei componenti open source vengono segnalate ai maintainer del progetto open source?
- Req. V7-V8** ■ Le patch di sicurezza sono distribuite gratuitamente a tutti gli utenti (non solo agli utenti premium)?
- Sett. 2026** ■ Il processo di segnalazione ad ENISA* (24h early warning, 72h notifica, 14gg report) è pianificato e pronto?

DOCUMENTAZIONE — Allegato II

- Doc 1** ■ Esiste una descrizione tecnica completa del prodotto con architettura software/hardware documentata (diagrammi)?
- Doc 2** ■ L'analisi del rischio di cybersicurezza è documentata con metodologia esplicita e matrice dei rischi?
- Doc 3** ■ Il fascicolo tecnico include i risultati dei test di sicurezza con evidenze concrete (output degli strumenti)?
- Doc 4** ■ La Dichiarazione di Conformità UE è stata predisposta (anche in bozza)?
- Doc 5** ■ Le istruzioni per l'utente includono informazioni sulla sicurezza, aggiornamenti e segnalazione problemi?
- Doc 5** ■ È stata dichiarata la data di fine supporto di sicurezza (end-of-security-support date) del prodotto?
- Doc 5** ■ Tutta la documentazione è disponibile nelle lingue dei Paesi UE in cui il prodotto è venduto?
- Doc 6** ■ Il fascicolo tecnico potrà essere conservato e aggiornato per almeno 10 anni?

4

FASE 4 — PIANO DI RIMEDIO E IMPLEMENTAZIONE

4.1 — Matrice di prioritizzazione dei gap

Per ogni gap identificato nella Fase 3, classifica la priorità usando questa matrice. La combinazione di impatto sulla sicurezza e facilità di implementazione determina l'ordine di intervento.

	■ BASSA COMPLESSITÀ (giorni / settimane)	■ ALTA COMPLESSITÀ (mesi / progetto)
■ ALTO IMPATTO sulla sicurezza (CVE critiche, config errate)	■ PRIORITÀ 1 — FAI SUBITO Quick wins ad alto impatto. Esempio: aggiornare librerie con CVE critiche (CVSS* >= 9.0), rimuovere password universali, abilitare TLS*.	■ PRIORITÀ 2 — PIANIFICA CON URGENZA Entro 4-8 settimane. Esempio: implementare autenticazione 2FA*, riscrivere componenti con vulnerabilità architetturali, implementare SBOM* generation.
■ BASSO IMPATTO sulla sicurezza (CVE medie, doc mancante)	■ PRIORITÀ 3 — NEL PROSSIMO SPRINT Nel prossimo ciclo di sviluppo. Esempio: migliorare la documentazione tecnica, pubblicare CVD* policy, abilitare log di sicurezza.	■ PRIORITÀ 4 — ROADMAP LUNGO TERMINE Nel roadmap a 6-12 mesi. Esempio: architettura zero-trust completa, implementazione HSM*, refactoring completo per principio minimo privilegio.

4.2 — Scheda d'azione per ogni gap

Crea una scheda d'azione per ogni gap identificato. Questo documento diventa il registro di avanzamento del progetto CRA condiviso con il cliente:

- **ID gap:** Es. GAP-001, GAP-002, ecc. — identificatore univoco per il tracciamento
- **Requisito CRA violato:** Es. Allegato I, punto 2(a) — assenza vulnerabilità note sfruttabili
- **Descrizione specifica:** Cosa esattamente manca o non è conforme. Include la CVE* o il test di riferimento
- **Prodotto/versione affetto:** Nome e versione del prodotto con il gap
- **Priorità (1-4):** Dalla matrice sopra
- **Azioni correttive:** Step concreti e verificabili da intraprendere
- **Responsabile:** Nome e ruolo della persona nel team del cliente che deve agire
- **Data target:** Scadenza realistica per la correzione
- **Evidenza di completamento:** Cosa verificherai per considerare il gap chiuso (output di uno strumento, documento, test)
- **Stato:** Aperto → In lavorazione → In verifica → Chiuso

4.3 — Correzioni tecniche tipiche per i gap più comuni

GAP: Librerie con CVE critiche non aggiornate

Azione immediata (Priorità 1). Per JavaScript/Node.js: esegui 'npm audit' per vedere le CVE presenti, 'npm audit fix' per correzioni automatiche sicure, 'npm audit fix --force' per correzioni che potrebbero introdurre breaking changes (attenzione: testa sempre dopo). Per Python: 'pip-audit' per vedere le CVE, 'pip install --upgrade [pacchetto]' per aggiornare. Per Java (Maven): 'mvn dependency:check' con OWASP plugin, aggiornamento delle versioni nel pom.xml. Per Go: 'govulncheck ./...' per trovare vulnerabilità, 'go get -u ./...' per aggiornare. IMPORTANTE: dopo ogni aggiornamento esegui la suite di test completa per verificare che nulla sia stato rotto dalle nuove versioni delle librerie.

GAP: Assenza di SBOM obbligatorio

Installa Syft: `'curl -sSfL https://raw.githubusercontent.com/anchore/syft/main/install.sh | sh -s -- -b /usr/local/bin'`. Genera SBOM dal progetto: `'syft dir:./src -o cyclonedx-json=sbom.json'` (formato CycloneDX* JSON) oppure `'syft dir:./src -o spdx-json=sbom.spdx.json'` (formato SPDX* JSON). Per container Docker: `'syft [image-name]:latest -o cyclonedx-json=sbom.json'`. Valida l'SBOM generato: `'cyclonedx validate --input sbom.json'`. Integra nel CI/CD*: aggiungi al pipeline GitHub Actions/GitLab CI un passo che genera e archivia l'SBOM come artifact ad ogni build. Scansiona l'SBOM per CVE*: `'grype sbom:./sbom.json'`.

GAP: Password/credenziali universali per tutti i dispositivi

Questo è uno dei gap più critici e più comuni nei dispositivi IoT*. Soluzione: implementare la generazione di password uniche per dispositivo durante il processo di produzione. Approcci consigliati: (1) generazione basata su numero seriale del dispositivo + salt crittograficamente sicuro (non reversibile), (2) generazione completamente casuale con password stampata sull'etichetta del dispositivo o consegnata con la documentazione, (3) primo accesso obbligatorio: il dispositivo forza l'utente a impostare una password personalizzata al primo avvio (first-boot wizard). Rimuovi TUTTI gli account con password predefinite conosciute (admin/admin, root/root, guest/guest, 1234, ecc.).

GAP: Assenza di CVD policy

La CVD* policy (Coordinated Vulnerability Disclosure) è obbligatoria e deve essere accessibile pubblicamente. Passo 1: crea il file security.txt (standard RFC 9116) nella root del sito web: `https://[sito-azienda]/.well-known/security.txt`. Contenuto minimo: Contact: `mailto:security@[dominio]` — l'indirizzo per ricevere segnalazioni, Expires: [data] — validità del file (max 1 anno), Policy: `https://[sito]/security-policy`. Passo 2: crea una pagina web 'Responsible Disclosure' o 'Vulnerability Reporting' con: indirizzo email dedicato (`security@[azienda]`), tempo di risposta garantito (es. entro 5 gg lavorativi), tempo massimo per rilasciare una patch (es. 90 gg per CVE medie, 30 gg per alte, 14 gg per critiche), processo di comunicazione con chi segnala, eventuale bug bounty. Passo 3: imposta la PGP key per `security@[azienda]` e pubblica la chiave pubblica nel security.txt.

GAP: Assenza di log di sicurezza

Implementa un sistema di logging strutturato (formato JSON) per gli eventi di sicurezza. Evento da loggare con priorità ALTA: tentativi di login (riusciti e falliti, con IP sorgente), modifiche alla configurazione di sicurezza (chi, quando, cosa), accesso a dati sensibili, errori di autenticazione o autorizzazione, riavvii del sistema. Evento da loggare con priorità MEDIA: aggiornamenti installati (versione, data, successo/errore), certificati TLS* in scadenza o scaduti, anomalie di traffico di rete. Piattaforme per log centralizzati: ELK Stack (Elasticsearch + Logstash + Kibana — soluzione open source completa), Graylog (alternativa open source più leggera), Loki + Grafana (per ambienti cloud-native). Retention (conservazione) dei log: minimo 3 mesi, raccomandato 12 mesi. I log devono essere in sola lettura (append-only) per chi non è amministratore.

GAP: TLS non configurato correttamente

Verifica la configurazione TLS* attuale: `'testssl.sh https://[tuo-dominio]'` oppure usa il servizio online SSL Labs (`ssllabs.com/ssltest`). Configurazione TLS minima richiesta dal CRA: TLS 1.2 (minimo assoluto, da abbandonare), TLS 1.3 (raccomandato). Disabilita esplicitamente: SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.1. Cipher suite da disabilitare: tutte le suite con DES, RC4, EXPORT, NULL, MD5. Cipher suite da preferire (in ordine): TLS_AES_256_GCM_SHA384 (TLS 1.3), TLS_CHACHA20_POLY1305_SHA256 (TLS 1.3), ECDHE-RSA-AES256-GCM-SHA384 (TLS 1.2). Configura HSTS (HTTP Strict Transport Security) con `max-age >= 31536000` (1 anno). Rinnova i certificati prima della scadenza (configura alerting 30 giorni prima).

5

FASE 5 — DOCUMENTAZIONE TECNICA OBBLIGATORIA

Obiettivo

5.1 — Struttura del fascicolo tecnico CRA

Il fascicolo tecnico è il documento centrale della conformità CRA. Deve essere redatto, mantenuto aggiornato per tutta la vita commerciale del prodotto, e conservato per almeno 10 anni dall'ultima unità prodotta. Di seguito la struttura con i contenuti minimi obbligatori per ogni sezione.

SEZ.

1

Descrizione generale del prodotto

- Nome commerciale, numero di modello, versioni hardware e software supportate
- Scopo del prodotto, uso previsto (intended use), categorie di utenti destinatari
- Diagramma dell'architettura di sistema: hardware + software + connessioni di rete (obbligatorio)
- Elenco completo di tutte le interfacce esterne: porte TCP/UDP aperte, API* REST/SOAP/GraphQL, interfacce fisiche (USB, UART, JTAG, SPI), wireless (Wi-Fi, Bluetooth, Zigbee, ecc.)
- Tipologia di dati elaborati, trasmessi, archiviati (con classificazione: pubblici, sensibili, personali)
- Ambienti di deployment supportati: cloud (quale provider), on-premise, edge computing, embedded, SaaS*
- Dipendenze da servizi di terze parti (API di terze parti, cloud services, ecc.)

SEZ.

2

Analisi del rischio di cybersicurezza

- Metodologia di threat modeling usata: STRIDE*, PASTA, LINDDUN, o altra (specificare)
- Lista degli asset da proteggere con classificazione di criticità (dati utente, funzionalità critiche, credenziali, chiavi crittografiche, infrastruttura)
- Lista dei threat actor (attaccanti potenziali): script kiddies, cybercriminali, competitor, insider, stati nazionali. Per ognuno: motivazioni, capacità stimate
- Matrice dei rischi: per ogni minaccia identificata → probabilità (1-5) × impatto (1-5) = livello di rischio (1-25). Classificazione: basso <5, medio 5-14, alto 15-19, critico 20-25
- Misure di mitigazione implementate per ogni rischio con livello di rischio residuo dopo la mitigazione
- Rischi residui accettati con motivazione documentata e firma del responsabile
- Data dell'analisi e piano di revisione (almeno annuale o ad ogni modifica significativa del prodotto)

SEZ.

3

SBOM e inventario componenti

- SBOM* completo in formato CycloneDX* JSON o SPDX* JSON (file allegato, non solo un link)
- Versione dello standard SBOM usato (es. CycloneDX 1.6) e dello strumento di generazione
- Lista dei componenti commerciali di terze parti (COTS — Commercial Off-The-Shelf) con informazioni sul fornitore
- Lista dei componenti open source con versioni precise, identificatori PURL*, licenze (GPL, MIT, Apache, ecc.)
- Policy di gestione delle licenze open source (compatibilità con licenze copyleft, uso interno vs. distribuzione)
- Dipendenze transitive documentate ove possibile (dipendenze delle dipendenze)
- Data di generazione dell'SBOM e versione del prodotto di riferimento

SEZ.

4

Risultati dei test di sicurezza

- Metodologia di test usata: black box (senza conoscenza del sistema), white box (accesso completo al codice), grey box (conoscenza parziale)

- Scope dei test: quali componenti, funzionalità e interfacce sono stati testati e quali no (con motivazione)
- Strumenti usati con versioni specifiche (es. 'Trivy v0.47.0', 'OWASP ZAP 2.14.0', 'Burp Suite Pro 2024.1')
- Risultati dei vulnerability scan: lista di tutte le CVE* trovate con punteggio CVSS*, stato (corretta/accettata/falso positivo)
- Risultati del penetration test (se eseguito): findings, severity, exploitation path, raccomandazioni
- Azioni correttive per ogni vulnerabilità trovata: cosa è stato fatto, data di correzione
- Risultati dei re-test (test di verifica) dopo le correzioni: conferma che le vulnerabilità sono state chiuse
- Data dei test, nome e firma del responsabile dei test (o dell'azienda di testing esterna)

SEZ.**5****Processo di gestione vulnerabilità**

- Processo interno di vulnerability management: come vengono ricevute le segnalazioni esterne, workflow di valutazione e classificazione, processo di sviluppo e rilascio della patch
- SLA* per la risoluzione per livello di gravità CVSS*: critiche (9.0-10.0) → N gg, alte (7.0-8.9) → N gg, medie → N gg, basse → N gg
- CVD* policy (Coordinated Vulnerability Disclosure — Politica di Divulgazione Coordinata) pubblicata e accessibile al pubblico (allegare copia)
- Indirizzo email di contatto per la sicurezza (security@[dominio]) con SLA di risposta dichiarato
- Processo di segnalazione ad ENISA* (Agenzia UE per la Cybersicurezza): chi fa cosa, con quale strumento, secondo quale template
- Registro degli incidenti di sicurezza degli ultimi 24 mesi (se disponibile): data, tipo, impatto, azioni intraprese

SEZ.**6****Dichiarazione di Conformità UE**

- Nome legale completo e indirizzo della sede legale del fabbricante
- Descrizione univoca del prodotto: nome commerciale, numero di modello, versione hardware/software
- Dichiarazione esplicita che il prodotto soddisfa tutti i requisiti applicabili del Regolamento (UE) 2024/2847
- Riferimento agli standard tecnici armonizzati applicati (se usati) con numero e titolo precisi
- Riferimento al CAB* (Conformity Assessment Body) e numero di certificato (se applicabile per Classe I/II)
- Nome, ruolo aziendale e firma autografa del rappresentante autorizzato del fabbricante
- Data (formato GG/MM/AAAA) e luogo (città, Paese) di firma

SEZ.**7****Istruzioni di sicurezza per l'utente**

- Guida alla configurazione sicura iniziale del prodotto (step-by-step, con screenshot se possibile)
- Come impostare o modificare le credenziali di accesso in modo sicuro
- Procedura per abilitare, configurare e gestire gli aggiornamenti di sicurezza (automatici/manuali)
- Come verificare che il prodotto esegua l'ultima versione del firmware/software
- Come segnalare problemi di sicurezza: indirizzo email, modulo web, tempi di risposta garantiti
- Data di fine supporto di sicurezza (end-of-security-support date) dichiarata **OBBLIGATORIAMENTE**
- Procedura di reset sicuro e cancellazione completa dei dati dell'utente (factory reset)
- Lingue: italiano + lingue di tutti i Paesi UE in cui il prodotto è venduto

6

FASE 6 — VALUTAZIONE DI CONFORMITÀ E MARCHIO CE

Obiettivo

6.1 — Procedura per prodotti NON CRITICI (autovalutazione interna)

- Verifica che tutti i gap identificati nella Fase 3 siano stati chiusi (tutti gli item della checklist marcati ■ Conforme o N/A — Non Applicabile)
- Esegui una revisione finale del fascicolo tecnico completo (idealmente da un revisore diverso da chi ha prodotto i documenti — 'fresh eyes review')
- Verifica che tutti i 7 elementi del fascicolo siano completi: descrizione prodotto, analisi rischio, SBOM*, test di sicurezza, vulnerability management, Dichiarazione di Conformità UE, istruzioni utente
- Firma la Dichiarazione di Conformità UE: deve essere firmata da una persona con autorità legale nel fabbricante (amministratore delegato, direttore tecnico autorizzato)
- Apponi il marchio CE* sul prodotto, sulla confezione o sulla documentazione allegata: deve essere visibile, leggibile, indelebile (almeno 5mm di altezza)
- Archivia il fascicolo tecnico in modo sicuro e accessibile: deve essere disponibile alle autorità di vigilanza su richiesta entro tempi ragionevoli (tipicamente 10 giorni lavorativi)
- Conserva il fascicolo tecnico per almeno 10 anni dall'ultima unità prodotta: pianifica subito la gestione di lungo termine
- Registra internamente la data di conformità per il tracking: inserisci nel sistema di gestione documentale

6.2 — Procedura per prodotti CRITICI CLASSE I

Il produttore può scegliere tra due opzioni:

Opzione A — Standard tecnici armonizzati (presunzione di conformità):

- Identifica gli standard armonizzati applicabili pubblicati sulla Gazzetta Ufficiale UE (cerca 'implementing acts CRA harmonised standards' su eur-lex.europa.eu)
- Principali standard applicabili: ETSI EN 303 645 (per dispositivi IoT* consumer), EN IEC 62443 (per sistemi industriali), EN ISO/IEC 27001 (per gestione sicurezza)
- Implementa tutti i requisiti dello standard identificato e documentali nel fascicolo tecnico
- Applica il marchio CE* con riferimento allo standard seguito nella Dichiarazione di Conformità

Opzione B — Valutazione da CAB* accreditato:

- Identifica un CAB* (Conformity Assessment Body — Organismo di Valutazione della Conformità) accreditato. In Italia: consulta il registro Accredia (accredia.it) nella sezione 'Organismi notificati CRA'. A livello europeo: NANDO database (ec.europa.eu/growth/tools-databases/nando)
- Invia richiesta formale di valutazione al CAB con: fascicolo tecnico completo, SBOM*, report dei test di sicurezza, descrizione del prodotto e del suo uso previsto
- Il CAB eseguirà: revisione documentale del fascicolo tecnico (2-4 settimane), verifica della correttezza dell'analisi del rischio, audit dei processi di development security, eventuale audit tecnico in loco o test indipendenti del prodotto
- Risolvi le non conformità segnalate dal CAB: possono richiedere uno o più cicli aggiuntivi di correzione e riverifica
- Ricevi il certificato di conformità dal CAB con numero identificativo
- Firma la Dichiarazione di Conformità UE con riferimento al numero di certificato CAB
- Apponi il marchio CE* + numero di identificazione del CAB sotto il marchio

6.3 — Procedura per prodotti CRITICI CLASSE II (CAB obbligatorio)

Per i prodotti Classe II la valutazione esterna è SEMPRE obbligatoria, non è possibile l'autovalutazione. Segui i passi dell'Opzione B sopra (6.2B), con le seguenti aggiunte:

- Il CAB deve essere specificamente accreditato per la valutazione di prodotti Classe II nel settore applicabile (ICS/SCADA*, sistemi biometrici, infrastrutture critiche, ecc.)
- I test eseguiti dal CAB sono più approfonditi: includono penetration test specifici e valutazione dell'architettura di sicurezza
- Il fascicolo tecnico per Classe II deve essere più dettagliato, con analisi del rischio estesa a scenari di attacco avanzati (APT — Advanced Persistent Threats)
- Tempi di valutazione tipici per Classe II: 3-6 mesi. Budget: € 30.000-80.000+ solo per la valutazione CAB

6.4 — Mantenimento della conformità dopo il marchio CE

ATTENZIONE: il marchio CE non è permanente. La conformità CRA richiede un processo continuo di monitoraggio e aggiornamento per tutta la vita commerciale del prodotto. Stabilisci questi processi permanenti con il cliente:

- **Vulnerability monitoring continuo:** Abbonamento ai feed CVE* per le tecnologie nel prodotto: NVD (National Vulnerability Database — nvd.nist.gov), GitHub Security Advisories (github.com/advisories), ENISA* advisories, CERT-EU alerts. Tool automatici: Dependabot (integrato in GitHub/GitLab), Renovate Bot.
- **Vulnerability scan periodico:** Cadenza consigliata: settimanale con strumenti automatizzati (Trivy in CI/CD*), mensile con scan più approfondito, semestrale per prodotti non critici, trimestrale per prodotti Classe I/II.
- **Aggiornamento SBOM* ad ogni versione:** Ad ogni nuova versione del prodotto (anche solo patch): rigenera l'SBOM e verifica che non siano state introdotte nuove CVE. Archivia ogni versione storica dell'SBOM per tracciabilità.
- **Security advisory dopo ogni patch:** Per ogni aggiornamento di sicurezza rilasciato: pubblica un security advisory con CVE corrette, gravità CVSS*, istruzioni per l'aggiornamento. Notifica via email gli utenti registrati.
- **Aggiornamento fascicolo tecnico:** Ad ogni modifica significativa del prodotto (nuova funzionalità, cambio di architettura, nuove dipendenze): aggiorna il fascicolo tecnico. Per modifiche sostanziali potrebbe essere necessaria una nuova valutazione di conformità.
- **Training annuale del personale:** Almeno una volta l'anno: sessione di formazione per il team tecnico su nuove vulnerabilità, best practice aggiornate, evoluzione del CRA (la Commissione Europea può emanare atti delegati e implementativi).
- **Preparazione processo ENISA:** Entro settembre 2026: testare il processo di segnalazione ad ENISA* con una 'fire drill' simulata. Verificare che le tempistiche (24h early warning, 72h notifica, 14gg report) siano realisticamente rispettabili con i processi interni.

GLOSSARIO OPERATIVO — Tutti i termini con asterisco (*)

Tutti i termini tecnici e gli acronimi usati in questa guida, con definizioni operative.

2FA / MFA	Two-Factor / Multi-Factor Authentication — Autenticazione a Due o Più Fattori. Metodo che richiede due o più prove di identità distinte: qualcosa che conosci (password), qualcosa che hai (smartphone, token), qualcosa che sei (impronta digitale, volto).
ASLR	Address Space Layout Randomization — Randomizzazione dello Spazio degli Indirizzi. Tecnica di sicurezza del sistema operativo che carica i programmi in posizioni casuali della memoria ad ogni avvio, rendendo molto più difficile sfruttare vulnerabilità come buffer overflow.
API	Application Programming Interface — Interfaccia di Programmazione. Insieme di protocolli che permette a sistemi software di comunicare. Le API esposte pubblicamente (es. API REST di un servizio web) aumentano la superficie di attacco del prodotto.
CAB	Conformity Assessment Body — Organismo di Valutazione della Conformità. Ente terzo indipendente accreditato per verificare la conformità dei prodotti alle normative. Per il CRA deve essere notificato alla Commissione Europea.
CE	Conformité Européenne — Conformità Europea. Marchio che attesta che il prodotto rispetta tutti i requisiti obbligatori delle normative UE applicabili. Per il CRA è obbligatorio dopo aver completato la procedura di conformità.
CI/CD	Continuous Integration / Continuous Deployment — Integrazione e Distribuzione Continua. Pratica di sviluppo software dove il codice viene testato e rilasciato automaticamente e di frequente, anziché in rilasci grandi e rari.
CISO	Chief Information Security Officer — Responsabile della Sicurezza delle Informazioni. Figura aziendale responsabile della strategia di cybersicurezza.
CRA	Cyber Resilience Act — Legge sulla Resilienza Cibernetica. Regolamento (UE) 2024/2847, la normativa europea sulla sicurezza informatica dei prodotti digitali.
CSIRT	Computer Security Incident Response Team — Team di Risposta agli Incidenti di Sicurezza. Ogni Stato Membro UE ha uno o più CSIRT nazionali. In Italia: CSIRT Italia dell'ACN (Agenzia per la Cybersicurezza Nazionale).
CVD	Coordinated Vulnerability Disclosure — Divulgazione Coordinata delle Vulnerabilità. Processo in cui un ricercatore segnala privatamente una vulnerabilità al produttore, che ha un periodo concordato per rilasciare una patch prima che la vulnerabilità venga resa pubblica.
CVE	Common Vulnerabilities and Exposures — Vulnerabilità ed Esposizioni Comuni. Sistema internazionale di catalogazione delle vulnerabilità software. Ogni vulnerabilità ottiene un codice univoco (es. CVE-2024-12345). Gestito da MITRE con supporto CISA.
CVSS	Common Vulnerability Scoring System — Sistema Comune di Punteggio delle Vulnerabilità. Scala 0-10 per la gravità: 0-3.9 Bassa, 4.0-6.9 Media, 7.0-8.9 Alta, 9.0-10.0 Critica.
CycloneDX	Standard OWASP per la creazione di SBOM in formato XML o JSON. Versione corrente: 1.6. È uno dei due formati riconosciuti dal CRA come valido per l'SBOM obbligatorio.
DAST	Dynamic Application Security Testing — Test Dinamico della Sicurezza. Tecnica di test che analizza un'applicazione in esecuzione cercando vulnerabilità, simulando un attaccante esterno. Strumenti: OWASP ZAP, Burp Suite.
DEP / NX	Data Execution Prevention / No-Execute — Prevenzione dell'Esecuzione dei Dati. Funzione hardware e software che impedisce l'esecuzione di codice in aree di memoria riservate ai dati, bloccando molti tipi di exploit.
DevSecOps	Development, Security, Operations. Approccio che integra la sicurezza in tutto il ciclo di sviluppo software, invece di trattarla come fase separata a fine progetto.

DDoS	Distributed Denial of Service — Attacco Distribuito di Negazione del Servizio. Attacco che usa molti sistemi compromessi contemporaneamente per sovraccaricare e rendere irraggiungibile un servizio o dispositivo.
ENISA	European Union Agency for Cybersecurity — Agenzia dell'UE per la Cybersicurezza. Sede ad Atene. Gestisce la piattaforma unica europea per la segnalazione degli incidenti CRA.
EUCS	EU Cybersecurity Certification Scheme — Schema Europeo di Certificazione della Cybersicurezza. Istituito dal Cybersecurity Act (Reg. UE 2019/881). Tre livelli: Basic, Substantial, High. Richiesto per i prodotti altamente critici del CRA.
HSM	Hardware Security Module — Modulo di Sicurezza Hardware. Dispositivo fisico tamper-resistant che esegue operazioni crittografiche in ambiente protetto. Usato per chiavi crittografiche di alto valore.
ICS / SCADA	Industrial Control Systems / Supervisory Control and Data Acquisition — Sistemi di Controllo Industriale. Usati in infrastrutture critiche: centrali elettriche, acquedotti, impianti produttivi.
IoT	Internet of Things — Internet delle Cose. Dispositivi fisici connessi a Internet che raccolgono e scambiano dati. Categoria principale soggetta al CRA: router, smart home, sensori industriali, ecc.
KEV	Known Exploited Vulnerabilities — Vulnerabilità Sfruttate Attivamente. Database CISA (USA) con CVE per cui esistono prove di sfruttamento in attacchi reali. La presenza in questo database determina l'obbligo di segnalazione CRA in 24 ore.
MDR	Medical Device Regulation — Regolamento Dispositivi Medici (UE) 2017/745. I dispositivi medici soggetti a MDR sono esclusi dal perimetro CRA.
NIS2	Network and Information Security Directive 2 — Direttiva (UE) 2022/2555. Si applica alle organizzazioni che gestiscono servizi essenziali. Complementare al CRA (che si applica ai prodotti, non alle organizzazioni).
PIE	Position Independent Executable — Eseguitibile Indipendente dalla Posizione. Tecnica di compilazione che permette all'eseguitibile di essere caricato in qualsiasi zona di memoria, necessaria per l'efficacia dell'ASLR.
PMI	Piccole e Medie Imprese. Definizione UE: < 250 dipendenti e fatturato ≤ 50 milioni €. Microimpresa: < 10 dipendenti e fatturato/bilancio ≤ 2 milioni €. Accesso a procedure CRA semplificate.
PURL	Package URL — Identificatore Univoco del Pacchetto Software. Formato standardizzato per identificare componenti software negli SBOM. Esempio: pkg:npm/%40angular/core@17.0.0
RBAC	Role-Based Access Control — Controllo degli Accessi Basato sui Ruoli. I permessi sono assegnati a ruoli (es. admin, user, auditor), non a singoli utenti. Implementazione del principio del minimo privilegio.
SBOM	Software Bill of Materials — Distinta Base del Software. Inventario completo machine-readable di tutti i componenti software del prodotto. Obbligatorio per il CRA. Formati accettati: CycloneDX o SPDX.
SPDX	Software Package Data Exchange. Standard ISO/IEC 5962:2021 per SBOM. Sviluppato dalla Linux Foundation. Alternativa a CycloneDX, entrambi riconosciuti dal CRA.
STRIDE	Framework per threat modeling: Spoofing (furto identità), Tampering (manomissione dati), Repudiation (rifiuto di responsabilità), Information Disclosure (fuga di informazioni), Denial of Service (blocco servizi), Elevation of Privilege (escalation di privilegi).
TLS	Transport Layer Security — Sicurezza del Livello di Trasporto. Protocollo per la comunicazione cifrata su reti. Versione minima accettabile: TLS 1.2. Consigliata: TLS 1.3. Le versioni precedenti (SSL, TLS 1.0, 1.1) sono obsolete e non devono essere usate.
TPM	Trusted Platform Module — Modulo di Piattaforma Attendibile. Chip hardware dedicato alla sicurezza (standard ISO/IEC 11889) integrato in molti PC e server. Gestisce chiavi crittografiche e verifica l'integrità del sistema.

VEX

Vulnerability Exploitability Exchange — Scambio di Informazioni sulla Sfruttabilità. Documento machine-readable che specifica, per ogni CVE in un prodotto, se è effettivamente sfruttabile nel contesto specifico di quel prodotto.

Documento operativo — non costituisce parere legale. Fonte principale: Regolamento (UE) 2024/2847 su eur-lex.europa.eu. Guide ENISA: enisa.europa.eu. Documentazione tecnica armonizzata: CEN/CENELEC.